

Access Control Policy — My Cash Pilot

Owner: Bryan Pham, CEO · Security contact: info@ahnmedia.com Version 1.0 · Effective 16 September 2026 · Next review 16 March 2027

This policy states who may reach My Cash Pilot, what each person may do once inside, how access is granted and removed, and how that is checked. It is a companion to the Information Security Policy and expands its section 2.

My Cash Pilot is an internal system operated by AHN Media for its own company accounts. It has no outside users and no public sign-up. Every account is created deliberately by the security owner for a named member of staff.

1. Principles

1. **Named accounts only.** One person, one account, tied to their work email. Shared and generic logins are not permitted, so every action in the audit log belongs to a person.
2. **Least privilege.** A role carries the smallest set of permissions that lets the work happen, and nothing beyond it.
3. **Enforced by the data layer, not the interface.** Hiding a button is not access control. Every rule below is applied on the server and, for data access, by the database itself.
4. **Deny by default.** A new role starts with no permissions; a capability is added only when a named job requires it.

2. Authentication

- **Two factors, always.** Every account requires a password and a TOTP authenticator app. There is no exemption, including for the owner.
- **Enforced in the database.** A PostgreSQL row-level security policy (`requiremfa`) refuses rows to any session that has not completed the second factor (assurance level AAL2). A session that reached the database directly with a single-factor token would still read nothing.
- **First sign-in.** A new account is required to enrol an authenticator before it can see any financial data.
- **Passwords** are set by the person, never issued over chat or email, and are stored by the identity provider as salted hashes — never in this application.
- **Sessions** are held in signed HTTP-only cookies over HTTPS, and expire.
- **No social or anonymous sign-in** is enabled.

3. Authorisation — the role matrix

Seven roles carry nine capabilities. The matrix lives in one place in the code and mirrors the database, which is the authority. Capabilities are checked on the server for every route that uses them.

Capability	owner	cfo	accountant	dept. lead	project mgr	employee	viewer
See compensation	✓	✓	✓				
See all company money	✓	✓	✓				✓
Edit financial records	✓	✓					
Disburse — send money out	✓	✓					
Categorise transactions	✓	✓	✓				
Manage integrations	✓	✓					
Manage people	✓	✓					
Manage projects	✓	✓		✓			
Read the audit log	✓	✓	✓				

Two deliberate separations:

- **Disbursing is not the same permission as editing.** An edit is reversible by another edit; a payment is not. Sharing one permission would have given payment authority to everyone who could fix a typo.
- **A department lead sees less than a viewer.** A viewer is trusted with the whole picture and no compensation data; a lead is trusted with their own unit.

4. Production assets and privileged access

Asset	Who has access	Control
Database (Supabase)	Security owner, system operator	Console login with MFA; row-level security on every table
Hosting and secrets (Vercel)	Security owner, system operator	Console login with MFA; secrets only as environment variables
Source control (GitHub)	Security owner, system operator	Account MFA; review before merge to <code>main</code>
Provider dashboards (Plaid, Intuit, Stripe)	Security owner	Account MFA
Administrative email	Security owner	Account MFA

- **The service-role database key**, which bypasses row-level security, exists only in server environment variables. It is never sent to a browser and is used only after the server has checked the acting person's capability.
- **The encryption key** for provider tokens is held the same way. Provider access and refresh tokens are encrypted with AES-256-GCM before they are written, so database access alone does not yield a usable banking credential.
- **No standing access to production data from a laptop.** Work is done against a development database; production data is read through the application.

5. Non-human authentication

Machine-to-machine access uses tokens and certificates, never a person's password:

- **OAuth 2.0** for provider connections — QuickBooks Online with refresh-token rotation, and Plaid Item access tokens obtained through Plaid Link. Bank credentials are entered inside the provider's own interface and never reach this application.
- **TLS** on every outbound and inbound connection, with HSTS set by the application.
- **A shared secret** authenticates the scheduled jobs that trigger syncing; a request without it is refused rather than run, and the routes refuse to run at all if the secret is unset.

6. The account lifecycle

Granting. The security owner creates the account, assigns the lowest role that fits the job, and records the approval. The person enrolls an authenticator at first sign-in.

Changing. A change of role is made by the security owner and written to the audit log with the actor, the time and the reason.

Removing. Access is revoked on the person's last day: the account is disabled, the authenticator factor is removed, and any provider connection they created is reviewed and reassigned or disconnected. Revocation is performed by hand, not by an automated identity system — this is stated plainly because the control that is claimed must be the control that exists.

Shared credentials. If a credential was known to someone who has left — an environment secret or a provider dashboard login — it is rotated as part of the same procedure.

7. Access reviews

Every six months, alongside the Information Security Policy review, the security owner:

1. lists every account and its role, and removes any that is no longer needed;
2. confirms every account still has an enrolled authenticator;
3. confirms the people with console access to the database, hosting, source control and provider dashboards are still the intended people, and that each console still has MFA enabled;
4. reviews the audit log for permission changes made since the last review;
5. records the date, the reviewer and anything changed in the review log below.

A review also runs immediately after anyone leaves and after any security incident.

8. Logging

Every permission change, connection, disconnection and import is written to an audit log with the actor, the time and the reason. Provider failures are recorded with the provider's own error identifiers so an incident can be traced on both sides. The audit log is readable by the owner, CFO and accountant roles.

9. Exceptions

An exception to this policy requires the security owner's written approval, a stated expiry date, and a compensating control. Open exceptions are listed at each review. There are none at version 1.0.

Review log

Date	Version	Reviewer	Change
16 Sep 2026	1.0	Bryan Pham, CEO	First issue